

# Data Collection & Processing Brief — for Counsel — Get Goods Gratis (Free)

⚠ **DRAFT — NOT LEGAL ADVICE.** This is an inventor-prepared **data map** that inventories, in one place, what personal data the platform collects, from whom, why, on what legal basis, who it is shared with, and how long it is kept — so counsel can run a privacy review efficiently and decide the open questions in §11. It is **distinct** from the public-facing **Privacy Policy** (the user-facing statement) and from `PRIVACY-LABELS-AND-DATA-SAFETY.md` (the app-store labels): this is the internal, lawyer-oriented inventory behind those. Bracketed items **[LIKE THIS]** are decisions for counsel/owner. Prepared 2026-09-13.

## 0. What this document is

A consolidated **data-processing inventory** (a records-of-processing-style map, GDPR Art. 30 in spirit) that gathers the data facts currently spread across the Privacy Policy, the Cookie & Tracking Notice, the app-store privacy labels, the founding-data design, the tax/1099 pipeline, and the per-feature legal briefs (Buddy Chat, social posting, shopping extension). Its job is to let counsel see the **whole** collection surface at once and confirm the lawful basis, disclosures, retention, sharing, and sensitive-data handling — not to state any legal conclusion.

**The compliance spine that shapes all of it:** everyday users are **closed-loop** (non-cashable Site Cash), the platform is **18+**, non-essential tracking is **off until opt-in** (strictest-standard applied worldwide), and money/identity/legal actions are permanently human-gated. Those choices narrow the data risk before any review begins.

## 1. Roles and the processing model

- **Controller:** the operating entity (Get Goods Gratis). **[Counsel/owner to confirm the legal entity — keep consistent with the EULA/ToS licensor and the patent assignment.]**
- **Processors / sub-processors** act on the platform's behalf under contract (see §5).
- **First-party-first posture:** the platform's own analytics and AI learn from **first-party** signals; a hard guard ( `FOUNDING_DATA_FIRST_PARTY_ONLY` ) refuses to collect any category not already disclosed as first-party, so "collect everything for the AI" can never silently become a new category of personal data without a privacy-policy update and counsel sign-off first (see `AUTONOMOUS-AI-AND-FOUNDING-DATA-DESIGN.md` ).

## 2. What data is collected (inventory)

| # | Category                             | Examples                                                                                                                                                 | Source                   | Primary purpose                                    | Notes / sensitivity                                                               |
|---|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|----------------------------------------------------|-----------------------------------------------------------------------------------|
| 1 | <b>Account / identity</b>            | Display name, email, hashed password, country/region, <b>date of birth</b>                                                                               | User                     | Run the account; <b>18+ age gate</b>               | DOB is collected to enforce the 18+ floor; password stored only as a secure hash  |
| 2 | <b>Transaction</b>                   | Points earned/spent, orders, limited payment <b>metadata</b> (no full card number)                                                                       | User + payment processor | Operate the points economy + checkout              | Full card data never stored (SAQ-A posture)                                       |
| 3 | <b>Behavioral / analytics</b>        | Page views, clicks, searches, scroll, navigation, survey-response timing/patterns, device/browser, <b>approximate location from IP</b> , app performance | Automatic                | Improve the Service, fraud detection, localization | Non-essential capture <b>opt-in only</b> ; identifiers masked                     |
| 4 | <b>Session screenshots (sampled)</b> | A few frames from a small rotating <b>sample</b> of sessions                                                                                             | Automatic (sampled)      | Diagnose usability/design                          | <b>OFF unless enabled</b> ; excluded when a user opts out of behavioral recording |
| 5 | <b>Communications</b>                | Support messages, in-Service assistant chats                                                                                                             | User                     | Support, assistant                                 | May contain whatever the user types                                               |
| 6 | <b>Third-party earning activity</b>  | Survey/offer completion signals                                                                                                                          | Survey/offer providers   | Credit activity, fraud checks                      | Inbound; signed webhooks                                                          |
| 7 | <b>Social connections</b>            | Permissions granted when a user connects Facebook / Instagram / X / Snapchat (e.g., post-on-                                                             | User opt-in              | One-tap social posting                             | Off until connected; see <code>SOCIAL-POSTING-ONE-TAP-</code>                     |

|    |                                      |                                                                                                                                                                                                                   |                                  |                                     |                                                                                                                                                     |
|----|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
|    | (optional)                           | behalf)                                                                                                                                                                                                           |                                  |                                     | AND-CONSENT.md                                                                                                                                      |
| 8  | Notifications                        | Web/app push subscription tokens                                                                                                                                                                                  | User opt-in                      | Send notifications                  | Off until enabled                                                                                                                                   |
| 9  | Tax / partner identity (sensitive)   | W-9: legal name, TIN, address, certification                                                                                                                                                                      | Business partners paid real cash | 1099 reporting + backup withholding | <b>Sensitive PII.</b> TIN masked everywhere except an admin export for the filing provider; TaxProfile owner-scoped (RLS). See TAX-1099-PIPELINE.md |
| 10 | Shopping helper (optional extension) | Merchant, order total, commission earned                                                                                                                                                                          | Extension, consent-gated         | Apply discounts + credit cashback   | Explicitly <b>not</b> collected: card/payment details, full cart/item list, general browsing history. Off until turned on; consent revocable        |
| 11 | Buddy Chat (social feature)          | Chat transcripts, <b>voice notes (recorded + transcribed for moderation)</b> , pairing/connect history, browsable profile fields (first name + interest categories only)                                          | User                             | Accountability pairing + moderation | Flag <b>wiretap/two-party-consent</b> and <b>BIPA-adjacent</b> voice questions; see BUDDY-CHAT-LEGAL-BRIEF.md                                       |
| 12 | Founding first-party panel data      | Comprehensive first-party activity across the disclosed manifest categories (profile, preferences, interactions, feature use, surveys, engagement, feedback, referrals, transactions, session telemetry, support) | User, consent-gated              | Train the platform AI               | First-party only (hard guard); recorded only once founding/PMF consent is on file                                                                   |

### 3. Sensitive / special-category and higher-risk data (call-outs)

- **TIN (partner W-9)** — the most sensitive identifier collected. Masked in all surfaces; full TIN only in an explicit admin export for the filing provider; owner-scoped storage. **[Counsel to confirm encryption-at-rest or provider custody before real TINs are collected at scale.]**
- **Date of birth** — collected to enforce the 18+ gate; users cannot self-grant the age flags.
- **Voice notes** — recorded and transcribed for moderation. **[Counsel: which jurisdictions' two-party/all-party wiretap-consent laws apply; is the in-app notice + consent sufficient; is Illinois BIPA triggered by voice capture even without voiceprint identification; retention/deletion of clips + transcripts.]**
- **Approximate location (from IP)** — used for currency/language/country and fraud, not precise geolocation.
- **Behavioral profiling + AI** — profiling of in-Service behavior feeds AI personalization/optimization. **[Counsel: is a DPIA warranted for the profiling + AI + session-screenshot sampling combination?]**

### 4. How data is used, and the limits on automated use

Data is used to operate accounts and the points economy; run the store, marketplace, and earning activities; localize; personalize recommendations and the assistant; test changes before release; detect fraud; provide support; meet legal/tax obligations; and secure the Service. Automated systems and AI inform how the Service is presented, but **decisions with legal or similarly significant effects — and any change to money-, identity-, or compliance-related controls — remain human-gated** (a permanent guardrail with a global kill switch).

### 5. Sharing, sub-processors, and international transfers

- **Sub-processors** (process data on the platform's behalf under contract): hosting/backend, database, payment processing (e.g., Stripe/PayPal), email/SMS (e.g., Twilio), analytics, AI/LLM and image-generation providers, and IP-geolocation / exchange-rate providers. **[Counsel: confirm a data-processing agreement is in place with each, and maintain the sub-processor list.]**
- **Third-party earning providers** (e.g., survey networks) receive only what is needed to credit activity.
- **Affiliate retailers** receive traffic only when a user follows an outbound affiliate/search link — **no account data is sent.**
- **Authorities / others** where required by law or to protect rights and safety.
- **No sale of personal information for money.** Where "sharing" for cross-context advertising is regulated, an opt-out is offered.
- **International transfers** — data may be processed outside the user's country; **[counsel to confirm the transfer mechanism — e.g., standard contractual clauses — for the markets served.]**

## 6. Consent and user choices (what's built)

---

- **Cookie/consent banner** — non-essential analytics/session-capture **off until opt-in; Reject** as prominent as **Accept**; granular categories; nothing pre-ticked; choice recorded to the **consent ledger**. The same banner carries the US "Do Not Sell or Share" and "Limit Use of Sensitive Personal Information" opt-outs. ( `ConsentBanner` , `recordCookieConsent` .)
  - **Behavioral-recording opt-out** in privacy settings (also excludes screenshot sampling).
  - **Data export** (machine-readable, includes behavioral + AI-profile + marketplace data).
  - **Account deletion** — anonymizes the profile and erases behavioral data, subject to records that must be retained by law.
  - **Feature-level consent** — shopping-extension ingestion, social-posting permissions, and founding-data collection are each separately consent-gated and off by default.
- 

## 7. Retention and deletion

---

Personal data is kept while the account is active and thereafter only for as long as needed to meet legal, tax, accounting, dispute-resolution, and fraud-prevention obligations, then deleted or anonymized. **[Counsel to approve a concrete retention schedule by data category — especially voice clips/transcripts (§3), TINs (legal retention for tax records), and behavioral logs.]**

---

## 8. Children

---

The Service is **18+**. The platform does not knowingly collect data from anyone under 18; the age flags cannot be self-granted; and if under-18 data is discovered it is deleted. **[Counsel: confirm what age-assurance beyond self-attested DOB is required given the social/voice feature.]**

---

## 9. Security (data-protection measures in place)

---

Password hashing; access controls; **row-level security** on sensitive records ( `TaxProfile` owner-scoped); **masking** of identifiers in behavioral events and of TINs everywhere except the admin filing export; signed inbound webhooks; no full card data stored. **[Counsel: confirm these meet the applicable security + breach obligations, and that a breach-notification plan exists.]**

---

## 10. Where this maps (source documents + code)

---

Public statement: `PRIVACY-POLICY.md` . App-store labels: `PRIVACY-LABELS-AND-DATA-SAFETY.md` . Cookies/tracking: `COOKIE-AND-TRACKING-NOTICE.md` . Consent + strictest-standard: `GLOBAL-COMPLIANCE-AND-LOCALIZATION.md` . Founding data + AI: `AUTONOMOUS-AI-AND-FOUNDING-DATA-DESIGN.md` , `MODEL-TRAINING-DATA-COUNSEL-NOTE.md` . Feature briefs: `BUDDY-CHAT-LEGAL-BRIEF.md` , `SOCIAL-POSTING-ONE-TAP-AND-CONSENT.md` , `SHOPPING-EXTENSION-AND-SERVICES.md` . Sensitive PII: `TAX-1099-PIPELINE.md` . Consent is recorded in the consent ledger.

---

## 11. Questions to finalize (for counsel)

---

1. **Lawful basis by category and market** (§2) — confirm the basis (consent, contract, legitimate interest, legal obligation) for each collection, per GDPR/UK GDPR/CCPA-CPRA/LGPD and other markets served.
2. **Founding "collect everything" posture** (§1/§2 #12) — is the comprehensive first-party collection adequately disclosed and consented, given it feeds an AI model?
3. **Sensitive-data handling** (§3) — TIN security at scale; voice recording (wiretap two-party consent + BIPA); DOB/age-assurance for the social/voice feature.
4. **DPIA** (§3) — is a data-protection impact assessment warranted for behavioral profiling + AI + session screenshots?
5. **Records of processing (Art. 30)** — should this brief be formalized into a maintained RoPA?
6. **Sub-processor DPAs + list** (§5) — confirm agreements are in place and the list is maintained.
7. **International transfer mechanism** (§5) — SCCs or equivalent for the markets served.
8. **Data-subject rights operations** — confirm the export/deletion/opt-out flows and any response-time SLAs meet each regime.
9. **Retention schedule** (§7) — approve concrete periods by category.
10. **"Do not sell/share" + sensitive-PI limits** (§6) — confirm adequacy of the opt-out presentation.

11. **Breach-notification plan** (§9) — confirm one exists and meets notification timelines.

*This is a draft data map, not legal advice, and is not a substitute for review and sign-off by a licensed attorney in the relevant jurisdictions. Related: [PRIVACY-POLICY.md](#), [PRIVACY-LABELS-AND-DATA-SAFETY.md](#), [COOKIE-AND-TRACKING-NOTICE.md](#), [FOR-YOUR-ATTORNEY.md](#).*